

EXEMPLE GRATUIT / ÉDITION 2026

ÉVALUATION DE LA SÉCURITÉ RÉSEAU

Exemple de rapport exécutif & technique

ASSESS -> FIX -> VALIDATE -> PROVE

Organisation fictive. Preuves synthétiques. Usage de démonstration uniquement. Aucun environnement client ou de production n'est représenté.

WeOwnIT / Network & Security Consulting

Risk-informed security engineering · Architecture · Remediation · Validation

Synthèse exécutive de l'évaluation

Des constats techniques au risque métier et à la remédiation validée.

CONCLUSION

L'environnement synthétique présente des faiblesses courantes concernant la protection du plan d'administration, la segmentation réseau, les accès privilégiés et la visibilité sécurité. Le risque principal résulte de la combinaison d'une connectivité trop large, d'une exposition privilégiée et d'une supervision incomplète.

RISQUE MÉTIER

Un poste utilisateur compromis peut créer un chemin vers le contrôle privilégié du réseau. Des flux est-ouest trop permissifs augmentent le potentiel de mouvement latéral, tandis qu'une journalisation incomplète réduit les capacités de détection et d'investigation.

RÉSULTAT

Cet exemple montre comment WeOwnIT relie les preuves, l'impact métier, la responsabilité de remédiation, les critères de validation et le risque résiduel - au lieu de s'arrêter à une liste de constats.

Contexte métier & actifs critiques

Les décisions de sécurité commencent par ce dont dépend l'activité.

CONTEXTE

ACME Manufacturing est une organisation fictive de 250 utilisateurs, avec un siège, deux agences, un ERP critique, des services internes, une connectivité distante et une gestion centralisée de la sécurité.

ACTIFS CRITIQUES

Pare-feu Internet; réseau d'administration; serveurs ERP et applicatifs; connectivité VPN; journalisation centralisée; identités administratives.

OBJECTIFS DE SÉCURITÉ

Disponibilité de la connectivité, intégrité des configurations privilégiées, confidentialité des données, segmentation entre zones de confiance et traçabilité des actions d'administration.

Périmètre, hypothèses & méthodologie

Un modèle reproductible d'ingénierie guidée par le risque.

PÉRIMÈTRE

Architecture, frontières de confiance, exposition administrative, segmentation, politiques de pare-feu, journalisation, accès privilégiés, sauvegarde et préparation à la reprise.

MÉTHODE

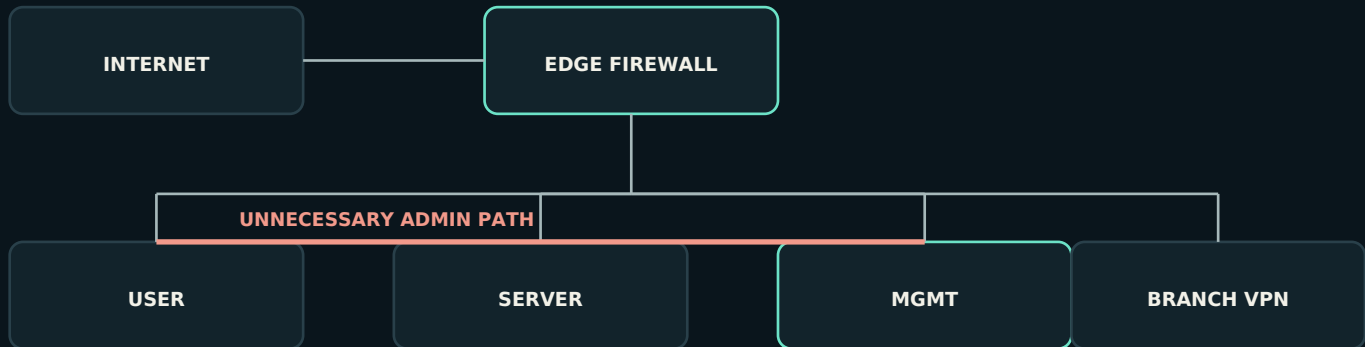
CONTEXT -> ASSESS -> ANALYZE -> PRIORITIZE -> REMEDIATE -> VALIDATE -> PROVE

CONFIANCE DES PREUVES

Cet exemple utilise des preuves SYNTHÉTIQUES / INFÉRÉES. En mission réelle, les preuves sont classées Confirmed, Observed, Inferred ou Not Tested.

Architecture & frontières de confiance

Identifier où une zone moins fiable peut atteindre un contrôle privilégié.



ZONES DE CONFIANCE

Internet / User / Server / Management / Security Management / Branch VPN

PROBLÈME OBSERVÉ

La zone User synthétique peut atteindre HTTPS/SSH d'administration du pare-feu. Cela crée un chemin d'attaque inutile depuis un segment poste de travail moins fiable vers un contrôle de sécurité privilégié.

ÉTAT CIBLE

L'administration provient uniquement de la zone de management ou d'un chemin distant approuvé, protégé par MFA, comptes nominatifs, moindre privilège et journalisation centralisée.

Registre des risques & priorisation

Prioriser les scénarios, pas les paramètres isolés.

R-01 - EXPOSITION DU PLAN D'ADMINISTRATION

Likelihood 4/5 | Impact 5/5 | Risque inhérent : CRITICAL |
Risque résiduel cible : LOW

R-02 - ACCÈS EST-OUEST EXCESSIF

Likelihood 4/5 | Impact 4/5 | Risque inhérent : HIGH |
Risque résiduel cible : MEDIUM

R-03 - JOURNALISATION INCOMPLÈTE

Likelihood 3/5 | Impact 4/5 | Risque inhérent : HIGH |
Risque résiduel cible : LOW

R-04 - ACCÈS PRIVILÉGIÉ SANS MFA

Likelihood 3/5 | Impact 5/5 | Risque inhérent : HIGH |
Risque résiduel cible : LOW

1	2	3	4	5
2	4	6	8	10
3	6	9	12	15
4	8	12	16	20
5	10	15	20	25

F-001 - Plan d'administration accessible depuis Us

Constat détaillé - HIGH

ATTACK PATH

Compromised endpoint -> User zone -> Firewall management -> Privileged control

ACTIF CONCERNÉ

Pare-feu de périphérie / plan d'administration

OBSERVATION

Les services administratifs HTTPS et SSH sont accessibles depuis le réseau général des utilisateurs.

SCÉNARIO DE MENACE

Un endpoint compromis peut établir une connectivité vers le plan d'administration du pare-feu. Combinée à un vol d'identifiants ou à une autre faiblesse d'authentification, cette situation crée un chemin vers un contrôle privilégié.

PREUVE ILLUSTRATIVE

Source 10.20.10.25 (USER) -> 10.20.100.1 TCP/443 REACHABLE; TCP/22 REACHABLE.

IMPACT POTENTIEL

Modification non autorisée des politiques, du VPN ou du routage; contournement de contrôles; modification des logs; interruption de service.

F-001 - Stratégie de contrôle & validation

Prévenir, limiter, détecter, restaurer - puis démontrer.

ATTACK PATH

Compromised endpoint -> User zone -> Firewall management -> Privileged control

PREVENT

Réseau d'administration dédié; sources administratives de confiance; MFA; comptes nominatifs.

LIMIT

Profils administrateur fondés sur les rôles; moindre privilège; protocoles d'administration restreints.

DETECT

Journalisation des connexions administratives, des échecs d'authentification et des changements de configuration.

RECOVER

Sauvegarde de configuration validée et procédure de restauration documentée.

RISQUE D'IMPLÉMENTATION

MEDIUM - restreindre l'accès d'administration sans connectivité alternative peut provoquer un verrouillage. Valider d'abord console/OOB.

PREUVES DE VALIDATION

MGMT -> HTTPS ALLOW; USER -> HTTPS BLOCK; WAN -> SSH BLOCK; MFA VERIFIED; événements d'administration visibles dans les logs centralisés.

RISQUE RÉSIDUEL ATTENDU

LOW si les sources autorisées, le MFA, les comptes nominatifs et la journalisation centralisée sont vérifiés.

F-002 - Accès réseau est-ouest excessif

Constat détaillé - HIGH

OBSERVATION

Une politique User-to-Server trop large autorise davantage de services que nécessaire au fonctionnement métier.

SCÉNARIO

Un poste compromis peut obtenir une connectivité inutile vers des workloads internes et augmenter les possibilités de mouvement latéral.

ÉTAT ACTUEL

USER -> SERVER : accès large / type any

ÉTAT CIBLE

USER -> APP : services métier requis uniquement; USER -> DB/MGMT : refusé sauf justification explicite.

VALIDATION

Test positif du flux applicatif requis et tests négatifs vers les ports base de données et management; revue des logs de trafic refusé.

RISQUE RÉSIDUEL

MEDIUM après politique de moindre privilège et supervision, selon les dépendances applicatives et exceptions approuvées.

Feuille de route & preuves de clôture

Transformer les constats en actions mesurables et attribuées.

0-7 JOURS

F-001 exposition management - Network Security - faible effort / risque de changement moyen.

0-30 JOURS

F-002 réduction des règles - Network Security + Application Owner - effort moyen. Imposer le MFA aux comptes privilégiés.

30-60 JOURS

Centraliser les logs et vérifier la couverture des événements d'administration. Valider la sauvegarde et la reprise.

CRITÈRES DE CLÔTURE

OPEN -> REMEDIATION PLANNED -> IMPLEMENTED -> VALIDATION REQUIRED -> VERIFIED -> CLOSED.

EVIDENCE PACK

Preuves de configuration, changement approuvé, tests positifs/négatifs, preuve dans les logs, risque résiduel et acceptation du propriétaire.

RÉSULTAT CLIENT

Synthèse exécutive + constats techniques + backlog de remédiation + architecture cible + plan de validation + preuves réutilisables.